Week 11: Connecting an application

Learning outcomes: CLO4, CLO6

Lesson

- **Three tiers:** presentation, application (your Python or Node.js code), data (MySQL).
- Read connection settings from environment variables. Use an account with only the rights the app needs.
- **SQL injection:** pasting input into SQL, e.g. `"... = '" + code + "'"`. Input `' OR '1'='1` changes the query.
- **Parameterized query:** SQL and values sent separately (`%s` in Python, `?` in Node.js). Parameters replace values only, not table or column names.
- Handle empty results and connection errors; always close the connection.

Worked example

Run `example.sql` (how (`setup/README.md`)). Then run the report app in apps/ (`apps/README.md`). Put your code in app/ (`weeks/week-11/app/README.md`).

Tables for this week

Read `cambodia`, write `student_work`. All columns are `NOT NULL`. Samples are the first two rows by code.

`cambodia.province`

Column	Type	Key	Meaning
`province_pcode`	`CHAR(4)`	PK	Province code
`province_name`	`VARCHAR(100)`		Province name (English)
`area_km2`	`DECIMAL(12,1)`		Area in km², one decimal place

Sample rows:

province_pcode	province_name	area_km2
KH01	Banteay Meanchey	6145.9
KH02	Battambang	11869.0

`cambodia.district`

Column	Type	Key	Meaning
`district_pcode`	`CHAR(6)`	PK	District code
`district_name`	`VARCHAR(100)`		District name (English)
`area_km2`	`DECIMAL(12,1)`		Area in km², one decimal place
`province_pcode`	`CHAR(4)`	FK	Province code

Sample rows:

district_pcode	district_name	area_km2	province_pcode
KH0102	Mongkol Borei	807.2	KH01
KH0103	Phnum Srok	761.7	KH01

Join keys: `district.province_pcode = province.province_pcode`.

Report app: input a `province_pcode` (e.g. `KH01`); returns `district_pcode`, `district_name` from `cambodia.district`, sorted by code. Read-only.

More: data guide (`data/README.md`).

Lab tasks

1. Run the report app (Python or Node.js) for one province; save command and output.
2. Find where the parameter is bound. How does it stop injection? Why can't a column name be a parameter?
3. Run the report with `' OR '1'='1`; check it returns no rows.
4. In your app: create a table in `student_work`, insert rows from `cambodia`, select, update one, delete one, all with parameters.
5. Handle a failed connection (wrong port) with a clear message and always close the connection. Optional: rank districts by area per province with `ROW_NUMBER()`.

Homework

1. Submit your app, setup steps and run output.
2. How do parameters, permissions and hidden passwords each protect the app?

Capstone sprint

C11 / Checkpoint 3: A working app with schema, import, objects and queries that a classmate can run from a fresh clone.

Submit

Answers in `work.sql`, reflection in `reflection.md`, output in `results/`. Commit and push. See SUBMISSIONS.md.